TASK A: SECURE A STUDENT ACCOUNT • 25 MARKS

Student: Ahmed Shakir **Batch/Group: A**

Mira's situation demonstrates how ordinary habits can expose personal information, academic work, and account access to security risks. These problems do not necessarily arise from carelessness or harmful intentions. However, a security-conscious approach requires identifying weaknesses early and taking practical steps to reduce their consequences.

A1–A2. Risk Assessment and Controls

Risk	Asset at risk	CIA impact	Practical control	Limitation
1. Reused short password	Email and learning portal accounts	Confidentiality: private messages and records may be exposed. Integrity: account details or work may be altered.	Use a long, unique password for each account, stored in a reputable password manager.	The manager must be protected; unique passwords do not stop every phishing or account attack.
2. Approving unexpected sign-in prompts	Accounts protected by multi-factor authentication (MFA)	Confidentiality and integrity may be affected if an unauthorised person gains access. Mira could also lose access to her account.	Reject unexpected prompts, report repeated requests, and use stronger MFA options such as number matching where available.	MFA can still be bypassed or manipulated, and deceptive prompts may continue.
3. Postponing device updates	Laptop, stored credentials, and project files	Unpatched flaws may enable unauthorised access or malware, threatening confidentiality, integrity, and availability.	Enable automatic security updates and restart the device when needed to complete installation.	Updates cannot remove every vulnerability, including previously unknown flaws.
4. Keeping only one project copy	Academic projects and related files	Availability: theft, hardware failure, or ransomware may make work unavailable. Integrity: files may be corrupted or changed.	Keep regular backups in a separate, protected location and test that files can be restored.	Backups may be outdated, corrupted, or affected by the same incident if not separated.
5. Sharing the laptop while signed in	Email, learning portal, and private documents	Confidentiality: another person may see private information. Integrity: work or account settings may be changed accidentally or deliberately.	Create a separate standard user account for the friend, lock Mira's session, and sign out of sensitive services when appropriate.	Separate accounts reduce accidental access but do not eliminate all risks from physical access, weak permissions, or malware.

Prioritised Actions

First, Mira should reject unexpected sign-in prompts and investigate repeated requests. These prompts may indicate an attempted account compromise. Rejecting them and reporting the activity reduces the chance of granting access to an unauthorised person.

Second, she should replace the reused password with a unique, strong password for each account, beginning with her email account and checking for suspicious active sessions. Reusing a password can allow one compromised account to expose another. Protecting email is particularly important because it may be used to recover other accounts.

Third, she should secure her academic work through separate backups and bring her laptop up to date. These steps reduce the consequences of data loss and known software vulnerabilities. She should also introduce separate user access before allowing anyone else to use the laptop.

These priorities address immediate account-access concerns first, followed by broader protection of her accounts, device, and academic work. They reduce risk without assuming that a security incident has already occurred.

A3. Authentication Versus Authorisation

Authentication checks a user's identity. When Mira signs in to her learning portal and completes the required MFA check, the portal attempts to verify that she is the person requesting access. **Authorisation** determines what that authenticated user is permitted to do. For example, Mira may be allowed to view course materials and submit assignments while being denied access to administrative functions. Authentication asks, "Who are you?"; authorisation asks, "What are you allowed to do?" Both are needed because verifying identity does not justify unrestricted access.

ASSESSMENT 01 | SECURITY FOUNDATIONS

TASK B: ANALYSE A SUSPICIOUS MESSAGE | 25 MARKS

The scholarship message contains several warning signs that deserve careful checking. Messages about financial help can create understandable hope and urgency for students. The right response is not to blame someone for feeling pressured, but to pause, protect their information, and verify the request through an official channel.

B1. Five Warning Signs (10 Marks)

No.	Evidence from the message	Why it needs scrutiny
1	"Open https://campus-awards.example/verify"	The college normally uses campus.example, but this link uses a different domain. Verify it independently before opening it.
2	"Reply-To: help@personal-awards.example"	The reply address differs from the sender address and uses another domain. This raises questions about who would receive a reply.
3	"FINAL WARNING - scholarship expires in 20 minutes"	The short deadline pressures the student to act quickly, leaving less time to check whether the message is genuine.
4	"enter your college password and OTP"	The message requests authentication secrets. Sharing them could allow someone else to access the student's account.
5	"Reply with a photo of your identity card"	An identity card contains sensitive personal information. Sending it to an unverified recipient could expose the student to identity misuse or fraud.

These are warning signs, not conclusive proof of who sent the message or what the website does.

B2. Safe Verification Process

The student should not click the link or reply to the message. Instead, they should open the college's established official portal directly or contact the scholarship office using contact details obtained independently from an official source. The office can confirm whether the scholarship notice is genuine. HTTPS encrypts the connection but does not prove that a website belongs to the genuine college. A familiar display name can also be copied. Neither feature alone establishes authenticity.

B3. Response Plan if a Password and OTP Were Entered

1. **Contain the possible compromise.** Using a trusted device, access the genuine portal through a known official route. Change the compromised password, change it anywhere it was reused, and ask the authorised IT team to revoke suspicious sessions and review MFA settings.
2. **Report promptly.** Contact the college's official IT/security team and scholarship office, explaining what was entered and approximately when. Never send the password or OTP to anyone claiming to provide support.
3. **Check for further misuse.** Review sign-in activity, recovery details, MFA settings, and unexpected account changes. Preserve the suspicious message for investigation. If identity-card information was also shared, report that too and follow official advice.

A student who reports the incident should be supported rather than shamed. Prompt reporting can limit harm and help the college protect others.

B4. One Fact That Cannot Be Established

The message alone cannot establish whether the scholarship was genuinely approved. The student should confirm this with the authorised scholarship office using independently verified contact details. Original email headers and relevant mail-system records could also help investigators examine the sender and message route.

ASSESSMENT 01 | SECURITY FOUNDATIONS

TASK C: TRIAGE A SIGN-IN ALERT | 25 MARKS

This analysis separates recorded evidence from possible explanations. Its purpose is not to blame the student or prematurely identify an attacker, but to understand what happened, protect the account, and prevent further harm. All times are IST, and the IP addresses are documentation examples. A different IP address alone does not prove an attacker is responsible.

C1. Four-Point Timeline: Evidence and Interpretation

Time	Observed Evidence	Interpretation
09:00–09:01	A password attempt from 192.0.2.10 succeeded, followed by an approved MFA event. The lab notes identify this as the usual classroom egress IP.	These events are consistent with a successful sign-in through the usual classroom network. They provide a comparison point but do not independently prove who performed the sign-in.
10:14–10:16	Two password attempts from 198.51.100.23 failed, followed by a successful password event from the same IP.	The sequence raises concern that someone may have obtained the correct password after repeated attempts. However, the logs do not establish how the password was obtained or who used it.
10:17–10:18	An MFA request from 198.51.100.23 was denied, followed by an approved request. The student said they approved a prompt because they thought it would stop the repeated requests.	The approval may have enabled an unauthorised sign-in. The student's statement offers a possible explanation for the approval, but further investigation is needed to establish how it relates to the recorded session.
10:20	A session was created from 198.51.100.23. The student stated that they had not signed in after 09:05.	The successful password event, approved MFA request, and session creation are consistent with a possible account compromise. The user's statement increases concern, but the identity of the person using the source IP remains unconfirmed.

C2. Likely Explanation, Alternative Explanation, and Additional Checks

Likely explanation: The account may have been accessed by an unauthorised person who knew or obtained the student's password. After two failed attempts, a password attempt succeeded. An MFA request was denied, but a later request was approved. The student's statement suggests that approving the repeated prompt may have contributed to the session being created. This explanation is plausible, but the logs do not prove how the password was obtained or who controlled the session.

Alternative explanation: The sign-in may have involved a legitimate activity from a different network or device that the student did not recognise or remember, or there may be an issue with how the authentication events were recorded or associated with the source IP. The student's statement makes an ordinary sign-in less consistent with the evidence, but the possibility should not be dismissed without further checks.

Two additional checks:

1. **Review authentication and session details.** The authorised IT team should examine available device information, browser or user-agent details, session records, and MFA event metadata. These details may help establish whether the session matches the student's recognised devices and activity.
2. **Verify the circumstances with the student and compare account records.** Using a trusted communication channel, ask whether the student was using a different network, device, or VPN, and confirm the circumstances of the MFA approval. Review relevant sign-in history and account changes for corroborating evidence.

Neither check should treat an IP address as proof of a person's identity.

C3. Three Prioritised Response Actions for the Authorised IT Team

1. **Preserve evidence and begin the investigation.** Secure relevant authentication logs, MFA records, session details, timestamps, and account-change records before they expire or are altered. Record the timeline and restrict access to the evidence. This protects the reliability of the investigation and reduces the risk of losing information needed to understand the incident.
2. **Contain the suspected compromise.** Revoke active sessions and relevant refresh tokens, reset the potentially compromised password through the official process, and review or reset MFA enrolment where appropriate. Temporarily restrict the account if necessary while its security is restored. These steps reduce the possibility of continued unauthorised access.
3. **Verify recovery and monitor for further activity.** Work with the student to secure the account, check recovery details and recent account changes, and review subsequent sign-in activity for suspicious behaviour. Explain why unexpected prompts should be denied and reported. The student should be treated respectfully because confusion about repeated MFA requests can happen, and a supportive response makes prompt reporting more likely.

The team should coordinate evidence preservation and containment so that protecting the account does not unnecessarily destroy information needed for the investigation.

C4. Incident Summary

The logs record two failed password attempts followed by a successful password event from 198.51.100.23. An MFA request was denied, another was approved, and a session was subsequently created. The student denies signing in after 09:05 but confirms approving a prompt because they thought it would stop repeated requests. These events indicate a possible account compromise, although the source IP does not identify the person responsible. The priority is to preserve authentication evidence, revoke potentially compromised sessions, secure the account, and investigate the session and MFA records.

TASK D: REVIEW AN AI SECURITY ANSWER

D1. Identify and Correct Five Unsafe or Unsupported Claims/Actions

The supplied AI answer contains five problems that could lead to unsafe decisions during a security incident. Although AI tools can help analyse information, their conclusions must be checked against available evidence and reliable guidance. In cybersecurity, an incorrect recommendation can expose someone's private information, destroy evidence, or make an incident more difficult to investigate.

No.	Unsafe or Unsupported Claim/Action	Correction and Explanation
1	*"The email is safe because it uses HTTPS."*	**Correction:** HTTPS encrypts information sent between a browser and a website, but it does not prove that a message or website is genuine. Fraudulent sites can also use HTTPS. Verify the scholarship through an independently located official college contact or portal, not the link in the message. See CISA Secure Our World.
2	*"The sign-in logs prove that the person using 198.51.100.23 stole the password."*	**Correction:** The logs associate authentication events with this IP, but do not identify the person or show how the password was obtained. Failed attempts followed by a successful password event, MFA activity, and session creation warrant investigation, but further session and authentication records are needed. The assessment expressly warns that a different IP alone does not prove an attacker's identity.
3	*"MFA prevents every account compromise."*	**Correction:** MFA adds protection, but does not guarantee that an account cannot be compromised. A user may approve an unexpected prompt or be deceived by phishing. Here, the student reports approving a prompt to stop repeated requests. Stronger, phishing-resistant MFA can reduce some risks, but unexpected prompts should still be reported. See CISA MFA guidance.
4	*"Delete the suspicious logs."*	**Correction:** Preserve sign-in, MFA, session, and account-change logs and protect them from alteration or deletion. They may establish event order, show possible compromise, and support recovery. Deleting them could destroy evidence needed for a reliable investigation. See CISA logging guidance.
5	*"Send the student's password to support so they can test it."*	**Correction:** Never send passwords or OTPs to support. IT staff should use approved investigation and account-recovery procedures and help reset compromised credentials if needed. Passwords must remain confidential even when a request appears trustworthy; support staff do not need the actual password to advise on account security. See CISA Secure Our World.

Overall correction: The original AI response treats limited evidence as conclusive, overstates MFA protection, proposes destroying evidence, and recommends exposing a secret. A responsible security analysis separates confirmed facts from assumptions, protects credentials, and preserves the information needed to investigate.

D2. Write a Better Prompt for an AI Tool

The following prompt directs the AI tool to analyse the supplied material carefully while protecting confidentiality and acknowledging uncertainty.

Improved AI prompt

Act as a cybersecurity analyst reviewing a fictional training scenario. Analyse only the synthetic message, sign-in logs, and statements supplied in the assessment. Do not assume that any real person, account, website, or IP address is involved.

For each conclusion, clearly distinguish between directly observed facts, reasonable interpretations, and information that remains unknown. Explain how the supplied evidence supports each interpretation and identify additional evidence that could help verify it.

Do not claim that an IP address identifies a particular person, that a successful login proves password theft, or that a security control guarantees complete protection unless the evidence supports the claim.

Never request, reproduce, or recommend sharing real passwords, OTPs, authentication tokens, or other confidential information. Recommend safe and proportionate response actions, including protecting the account, preserving relevant evidence, and reporting through authorised channels.

State uncertainty clearly, identify unsupported claims, and use trustworthy references that can be independently checked. If the supplied evidence is insufficient to establish a conclusion, explicitly explain that limitation.

This prompt establishes clear boundaries for the AI tool. It prioritises evidence, protects sensitive information, and requires the tool to acknowledge uncertainty rather than invent explanations. This is important because generative AI systems can produce plausible but inaccurate content, a limitation discussed in the NIST Generative AI Profile (AI 600-1).

D3. Corrected Security Advice

Security decisions should be based on verified evidence rather than assumptions. HTTPS protects the connection between a browser and a website, but it does not prove that the website or message is genuine. Similarly, a source IP and a successful sign-in do not identify a person or establish how a password was obtained. MFA strengthens account security, but unexpected authentication prompts must never be approved simply to stop repeated requests.

Students should verify suspicious messages through official channels, keep passwords and OTPs private, and report unexpected sign-in activity promptly. If a compromise is suspected, authorised IT staff should preserve relevant logs, revoke potentially compromised sessions, secure the account, and investigate additional evidence. Students should receive clear guidance and support rather than blame, because a respectful reporting process helps protect individuals and the wider college community.

D4. AI-Use Declaration and Two Evidence/Reference Notes.

AI-Use Declaration

OpenAI, Google Gemini, Claude AI were used to help organise and draft this section and to identify relevant reference materials. AI-generated suggestions were treated as assistance rather than unquestionable facts. The final submission should be reviewed against the supplied assessment evidence and cited sources before submission. I accept responsibility for the accuracy and content of my final report.

Note: Keep this declaration consistent with the assistance you actually used and the checks you complete before submitting the report.

Reference Note 1: CISA and Account Security

The Cybersecurity and Infrastructure Security Agency (CISA), through its Secure Our World guidance, identifies phishing awareness, strong passwords, multi-factor authentication, and software updates as important protective measures. This supports correcting the claims that HTTPS proves legitimacy and that MFA guarantees complete protection. The guidance supports practical steps to protect accounts without unnecessarily blaming users who encounter deceptive messages.

Reference: Cybersecurity and Infrastructure Security Agency (CISA), Secure Our World

Reference Note 2: NIST and AI Reliability

The National Institute of Standards and Technology (NIST), in its Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (AI 600-1), discusses confabulation, in which generative AI produces and confidently presents incorrect or false content. This supports verifying AI-generated claims against supplied evidence, identifying uncertainty, and avoiding acceptance of a confident answer without checking its accuracy.

Reference: National Institute of Standards and Technology (NIST), AI 600-1 PDF

Final Review

This task identifies five unsafe claims or actions, provides an improved AI prompt, gives corrected security advice within the required word limit, and includes an AI-use declaration with two evidence/reference notes. The central principle is that cybersecurity advice should be technically accurate, grounded in evidence, and respectful of the people affected by an incident.